

Guide du TP 3 : XSS, CSP et en-têtes de protection

TP 3 · XSS, CSP et en-têtes

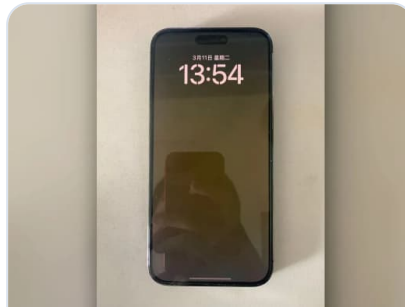


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



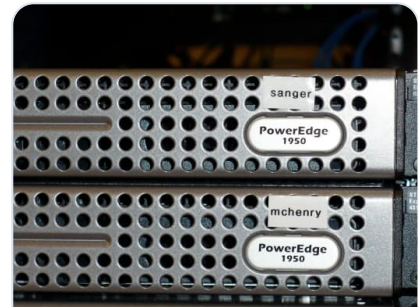
Ordinateur portable

L'ordinateur que l'on emporte partout



Smartphone

Messages, photos, argent mobile et codes



Serveur

Fournit fichiers, messagerie ou site web aux autres

Photos issues de Wikimedia Commons : Ordinateur portable, Ahunt, CC0 · Smartphone, 茅野ふたば, CC BY-SA 4.0 · Serveur, Florence Devouard, CC BY-SA 4.0.

CADRE ET LIMITES

- ◆ Tu analyses uniquement des fichiers fournis ; ne teste jamais un site réel sans autorisation écrite.
- ◆ Les exemples ci-dessous utilisent des valeurs inventées qui ne sont pas celles du labo.

Bien distinguer les contextes de sortie

- ◆ Corps HTML : préfère un échappement automatique du moteur de gabarits.
- ◆ Attribut HTML : garde des guillemets autour de la valeur et échappe le contenu.
- ◆ Bloc script : ne concatène pas une donnée utilisateur dans du JavaScript brut.
- ◆ URL : valide le schéma attendu avant d'insérer une valeur.

Lire une politique CSP

- ◆ `default-src` sert de repli si une directive spécialisée comme `script-src` manque.
- ◆ Un `nonce-...` ou une empreinte `sha256-...` autorisent seulement un script en ligne précis.
- ◆ `object-src 'none'` et `base-uri 'none'` ferment deux surfaces utiles en défense en profondeur.
- ◆ Une mise en service prudente commence par `Content-Security-Policy-Report-Only` puis passe en blocage une fois la vérification terminée.



Grille simple pour les en-têtes du TP

- ◆ CSP non vide : 2 points.
- ◆ HSTS avec `max-age` de 31536000 au minimum et `includeSubDomains` : 2 points.
- ◆ `X-Content-Type-Options: nosniff` : 1 point.
- ◆ `Referrer-Policy` prenant la valeur `strict-origin`, `strict-origin-when-cross-origin` ou `no-referrer` : 1 point.
- ◆ `X-Frame-Options` prenant la valeur `DENY` ou `SAMEORIGIN` : 1 point.
- ◆ `Permissions-Policy` non vide : 1 point.



Bash ou Git Bash

BASH

```
cat > demo-templates.txt <<'EOF'
GX1 | corps HTML échappé | <h2><%= room.name %></h2>
GX2 | attribut sans guillemets | <input value=<%- query.term %> data-kind="search">
EOF
raw_demo=$(grep -c '<%- ' demo-templates.txt)
cat > demo-headers.csv <<'EOF'
page;csp;hsts;x_content_type_options;referrer_policy;x_frame_options;permissions_policy
/demo;PZ;max-age=31536000; includeSubDomains;nosniff;strict-origin;DENY;camera=()
EOF
rows_demo=$(awk 'END{print NR-1}' demo-headers.csv)
printf 'Exemple de comptage de sorties brutes : %s ligne(s).\nExemple de lecture du tableau des en-têtes : %s page(s).\n'
"$raw_demo" "$rows_demo"
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.



PowerShell 5.1

Les fichiers du labo sont en UTF-8 : avec Windows PowerShell 5.1, ajoute `-Encoding UTF8` dans `Get-Content` et `Import-Csv`.

POWERSHELL

```
@'
GX1 | corps HTML échappé | <h2><%= room.name %></h2>
GX2 | attribut sans guillemets | <input value=<%- query.term %> data-kind="search">
'@ | Set-Content -Encoding UTF8 demo-templates.txt
$rawDemo = @(Get-Content -Encoding UTF8 demo-templates.txt | Where-Object { $_ -match '<%- ' }).Count
@'
page;csp;hsts;x_content_type_options;referrer_policy;x_frame_options;permissions_policy
/demo;PZ;max-age=31536000; includeSubDomains;nosniff;strict-origin;DENY;camera=()
'@ | Set-Content -Encoding UTF8 demo-headers.csv
$rowsDemo = @(Import-Csv -Delimiter ';' -Path demo-headers.csv).Count
"Exemple de comptage de sorties brutes : $rawDemo ligne(s)."
"Exemple de lecture du tableau des en-têtes : $rowsDemo page(s)."
```



Visionneuse du site

Dans la visionneuse, commence par filtrer des mots génériques comme `unsafe-inline`, `nonce-`, `violated-directive`, `nosniff` ou `inline`, puis relis la ligne au complet avant de conclure.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).